

Field Based Permissions

Understanding the GraphQL Schema

```
type Query {  
  accounts: [Account!]  
}
```

```
type Account {  
  owner: String!  
  number: ID!  
  balance: Float!  
}
```

- Query: The entry point of your API
 - accounts returns a list of Account objects
- Account Type:
 - owner: Name of account holder
 - number: Unique account number
 - balance: Sensitive field showing current balance

Field Based Permissions

Why Use Field-Based Permissions?

Not every API consumer should see everything.

Internal user can query:

```
query {  
  accounts {  
    owner  
    number  
    balance  
  }  
}
```

External user tries to access `balance` and gets:

```
{  
  "errors": [  
    {  
      "message": "field: balance is restricted on  
type: Account"  
    }  
  ]  
}
```

Setting Up Field Based Permissions

Restricted and allowed types and fields can also be set up via Tyk Dashboard.

Optional: Configure a Policy from System Management > Policies > Add Policy.

- From System Management > Keys > Add Key select a policy or configure directly for the key.
- Select your GraphQL API (marked as GraphQL).
- Enable either Block list or Allow list. By default, both are disabled. It's not possible to have both enabled at the same time - enabling one switch automatically disables the other.

Setting Up Field Based Permissions - Blocklist

By default all Types and Fields will be unchecked. By checking a Type or Field you will disallow to use it for any GraphQL operation associated with the key.

For example, the settings illustrated below would block the following:

- code and countries fields in Continent type.
- latt and longt fields in Coordinates type.

Types

Filter Types

Types list SELECT ALL DESELECT ALL

- ☐ Country
- ☒ Coordinates
- ☒ Continent
- ☐ Language
- ☐ State
- ☐ Query

Fields

Filter field names

Coordinates SELECT ALL DESELECT ALL

- ☒ latt
- ☒ longt

Continent SELECT ALL DESELECT ALL

- ☒ code
- ☐ name
- ☒ countries

Setting Up Field Based Permissions - Allowlist

By default all Types and Fields will be unchecked. By checking a Type or Field you will allow it to be used for any GraphQL operation associated with the key.

For example, the settings illustrated below would only allow the following:

- code field in `Continent` type.
- code and name fields in `Language` type.

Types list [SELECT ALL](#) | [DESELECT ALL](#)

- ☐ Country
- ☐ Coordinates
- ☒ Continent
- ☒ Language
- ☐ State
- ☐ Query



☐ longt

Continent [SELECT ALL](#) | [DESELECT ALL](#)

- ☒ code
- ☐ name
- ☐ countries

Language [SELECT ALL](#) | [DESELECT ALL](#)

- ☒ code
- ☒ name